

What exactly should we be logging?

A structured look at what data to collect for security purposes and when to collect it

As a security architect and the technical leader for the Logging Made Easy project, I am often asked “*what logs should I be collecting?*”

I absolutely hate the standard ‘[it depends](#)’ response. So, I’ve been answering with a question of my own: “*For what?*” This has led to a number of interesting discussions on the topic of who should be logging what, and when.

This blog-post is my attempt to extract the wisdom from these conversations. To make this more accessible I’ve chosen to structure these ruminations around the 14 headings used by the Adversarial Tactics, Techniques, and Common Knowledge ([ATT&CK](#)) taxonomy, from MITRE.

By the time you’ve finished reading you will have the tools and knowledge to ask the right questions about your systems. You can then identify what log data will help you to spot the activities which attackers are likely to use as they hide, persist and explore your systems.

Available resources

Before getting down to specifics, take some time to think about the logging practices, sources and tools available to you.

Picking the right tool is part of the journey – you wouldn’t expect a chef to use a single knife, nor would you expect a developer to work with a single technology stack. You need to decide what are the ‘right tools for the job at hand’.

Doing away with ‘one size’ solutions

The now deprecated Good Practice Guide 13 (GPG 13) attempted to state a minimal expected standard for event logging. Unfortunately, this prescriptive approach turned out to be restrictive because it didn’t factor in the varying types of deployments possible and assumed that all logging sources were available and meaningful.

In the face of this problem, it’s tempting to just turn your logging capability up to 11 and gather everything you can. This ‘everything on’ approach seems simple, but is likely to waste storage and processing resources, as you handle the inevitable deluge. It is also very likely that you will only increase the noise within your monitoring, making important events harder to detect and respond to.

In case your were wondering, turning event logging off is not the answer either. Unfortunately, there’s no one-size-fits-all solution to this problem.

Alternatives to ATT&CK

There are a few different ways to determine the logging set up that is most suitable for you. In this blog-post we’ll be exploring the use of the ATT&CK framework, but there are at least a couple of other approaches:

➤ Outcomes based:

You could begin by agreeing what outcomes you want to be able to achieve with your logs. You may well already have these as they can form part of the key design requirements for a system. An example logging requirement could be: *We must be able to tell who was logged on to any system at any specific time in the past year, and whether they logged on locally or remotely.*

Many sources of cyber security guidance, including things such as the NCSC’s guidance on [protecting bulk personal data](#) and [Cyber Assessment Framework \(CAF\) Objective C](#), provide some contextualised outcomes.

➤ Threat Modelling and Attack Trees:

In the NCSC’s upcoming guidance on How to build a SOC, we use threat modelling and attack trees to identify logging requirements. We then link these newly found logging requirements to the components of the system that

would likely be attacked, and identify the corresponding log files that would include the right data.

MITRE ATT&CK

The [ATT&CK](#) taxonomy, from MITRE, helps to define adversary tactics and techniques, based on real-world observations, in a readable format.

We can use this type of framework to review how an attack is achieved, and what logging sources can be used to track those events.

The MITRE ATT&CK framework or matrix divides 'tactics' and 'techniques' into 14 discreet sections (at the time of writing). Let's review each topic, or tactic, in turn.

1 Reconnaissance

[This technique](#) will be specific to your environment and connectivity, but you can expect that an attacker will attempt to acquire a certain amount of knowledge, in order to improve their chances of success.

Some techniques, such as active scanning of your boundary controls, can be detected, but open source collection of information cannot.

2 Resource Development

In order to legitimise, or improve the chances of success for steps discussed later, an attacker will [develop and purchase resources](#) such as infrastructure or digital assets to trick users or systems into divulging information. For example, this could involve copying legitimate websites to facilitate phishing attempts, or purchasing digital certificates and domains.

Attackers will also quite often compromise third-party infrastructure and compute resources to provide themselves with the infrastructure they need.

It may be difficult to capture logs that can be used to directly identify a threat's resource development. However, you may see evidence of log-in attempts from old, legacy accounts that attackers have either purchased or found from a leaked list of accounts and credentials.

3 Gaining Initial Access

[This stage](#) refers to an attacker pivoting from passive information gathering to actively gaining first access.

When considering how an attacker may gain initial access, you should take into account what they have been able to learn from the initial stages (section 1 & 2), and what kind of access they have to your systems.

You may feel that [phishing](#) is only a credible threat if your business operates remotely and is dependent on email. You may not consider a local attack to be a credible threat so you may justify prioritising phishing over [hardware additions](#) (such as key loggers or network taps). Conversely, you may not rely on email, but are mindful of the risk of insider-threat. In this case, you *will* need to consider physical attacks.

It is easy to imagine that 'Initial Access' requires human assistance to succeed – like opening an attachment or following a link. But that's only half the story, attackers can also leverage [External Remote Services](#) as an attack vector. For example, exposed services such as VPNs or Remote Desktop servers can afford an attacker an opportunity to gain access remotely and *without human interaction*.

The aim of reviewing this technique within the context of your IT estate is to identify where in your system an attacker is able to begin an attack, or further develop their reconnaissance. Or, if reviewing your existing logging coverage, develop areas where improvements can be made. This is part of the reason why providing a prescriptive list of logging sources is not helpful – knowledge of your environment is the key to deploying an effective logging solution.

4 Execution of Attacker controlled code

This tactic is closely aligned with some of the initial access attempts. For example, [opening an unknown email attachment](#) that has a [malicious payload that executes when opened](#).

However, execution does not have to be solely achieved by user interaction. Execution without human intervention can be achieved by attackers uploading files to exposed services that do not sanitise input.

This topic highlights why robust lock-down of [End User Devices](#) is essential. For example, if a typical user profile does not require privileges to run macros or unsigned PowerShell commands, then remove it.

Not being able to run a malicious script may protect against exploitation. Logging attempts to run such scripts gives you a chance to spot that an attack has been attempted and begin remediation.

5 Persistence

If an attacker has been successful and their code has been executed, their next job is to ensure that they are [able to retain access after any interruption](#) i.e. process is terminated or after a restart.

There are a number of ways this could be achieved. Adding a boot or start-up process, allowing delegated access from a malicious account, is one example. An alternative involves adding functionality to legitimate software – browser extensions, for example.

Are there gaps in your logging that would allow an attacker to persist undetected? Do you monitor for account creation, or account access from strange locations? Do you allow browser extensions to be installed? Do you review applications that start on boot?

6 Privilege Escalation

[Privilege escalation](#) refers to the methods attackers use to move from an account with limited access to one with greater rights. For example, a standard user to an administrator. The ATT&CK framework has broadly defined this section using 12 techniques.

Given the numerous routes an attacker can seek to gain privilege escalation, you need to consider which techniques are relevant based on your IT estate. For example, you could gather metrics about any unpatched running processes, or processes that are perceived to be more susceptible to process injection or hijacked execution-based attacks due to their exposure and common use. These logging sources may not be a high-priority if you have strong and robust *principle of least privilege* applied to your user account hierarchy, supported by multi-factor authentication but evidence of attempt needs to be investigated.

Some privilege escalation techniques can be used by administrators or services for legitimate reasons – for example, automated software updates or determining faults. It is reasonable to expect a number of false-positives if your administrators regularly use these tools, but you should be aware of the number of nominal behaviours and investigate if those numbers alter or become more repetitive – indicating a potential compromised account.

Once you have assessed how privilege escalation attacks can occur within your systems, not only should you be able to determine your most vulnerable areas, but you should also be able to identify areas where logging would be useful and where other techniques for mitigation would be better suited.

7 Defence Evasion

If an attacker has achieved execution, persistence and privilege escalation, they would be very keen to avoid being detected. Within the MITRE ATT&CK framework, there are several [techniques that can be used to evade detection](#).

One common way of doing this is to name an executable to be the same as a legitimate process, so upon a cursory inspection, nothing looks awry. This is why capturing process hashes is important.

Another attacker trick is to replace or patch essential libraries or functions to add hidden functionality. On Windows hosts, attackers may seek to edit registry variables, hijacking legitimate entries to hide their malicious executables or functionalities.

8 Credential Access

Should the attempts to exploit system vulnerabilities fail, an attacker may turn their attention to your users, attempting to [compromise their accounts](#). This can be achieved by brute-forcing accounts, man-in-the-middle attacks, or network sniffing. An impact of credential access is onward [credential stuffing](#) attacks following breaches.

The [NCSC's guidance on password policies](#) states that additional logging for the detection of password compromise should be implemented, but you may wish to go further. Would you normally expect login events to occur outside of normal office hours? What about from different locations or machines?

9 Discovery

The [discovery tactic](#) is the attempt by an attacker to gain insights about your network or service. This knowledge can be used to increase the likelihood of an attack being successful. This can range from gathering information using legitimate features (e.g. DNS enumeration), to understanding what peripherals are attached to a device such as USB storage or microphones.

Legitimate tools can be used for the discovery process, so preventing it is not as easy as locking down processes from known vendors. You have to understand the context of your users. Your IT team running 'net.exe' commands is not unusual, but someone from a finance department running that process may be highly irregular and should be investigated.

Information from this phase can assist an attacker in identifying seldom updated machines, typical user behaviour, or users of machines with high levels of privilege to target.

10 Lateral Movement

[Lateral movement](#) refers to an attacker moving from one compromised machine to attack another. This is normally necessary for an attacker to achieve their goal, e.g. deploying ransomware.

Would you expect users to log into a single machine or many machines in a day? This kind of behaviour may indicate a compromised user account being used to move within the network.

Lateral movement can be achieved by the use of bespoke tools or tools that exist within the environment, such as native remote desktop features – these tools are often referred to as Living off the Land Binaries or LOLBINS.

The use of these tools, including any new executables and log-in events should be recorded to help detect lateral movement attempts.

11

Collection

Collection refers to the selective theft of information from the target system. This can be traditional information such as binary files, or novel sources, such as audio taken from a device, screenshots, or the clipboard.

Logging these events may be as simple as monitoring for certain processes that are used to capture screens or inputs. However, more capable attackers may hide such activities by copying 'typical' behaviour – do you normally back data up to a cloud service? An attacker may do the same.

12

Command and Control

Command and Control is the means by which an attacker orchestrates the compromised devices to control them. This is a common feature of botnets that conduct email spam campaigns or how co-ordinated DDoS attacks are facilitated.

A common way of conducting Command and Control is by DNS records, as this is typically always allowed to transit a network and can hide in the noise of legitimate traffic. Capturing and logging DNS requests to newly discovered domains or a number of sudden requests from many machines to the same domain could be indicative of malware trying to 'phone home'.

Using DNS is not the only way Command and Control is achieved – in some cases, web traffic or a proprietary encrypted channel can be co-opted. You should review Command and Control techniques listed within the MITRE framework and identify those that could be leveraged within your systems.

13

Exfiltration

If an attacker's aim is to **steal data as part of an attack**, they will need to move it to infrastructure they control – as described in the 'Resource Development' stage. This could be achieved by moving data using bespoke processes or protocols that could be detected by network logging, or through existing services, such as cloud hosting that is already permitted through your firewalls.

This tactic is also applicable to insider threats, as data could be exfiltrated via several means for example, removable media. You may have IT policies that state that you should not use removable media (a popular exfiltration mechanism) but do you log USB insertion events?

14

Impact

Impacts are the perceived or demonstrable effects of the previous sections. It is worth remembering that not all attacks will result in the manipulation, interruption, or destruction of systems and data; this will depend on the attacker's aims. Consider the difference in the objective between industrial espionage and opportunistic ransomware.

Since not all attacks or breaches into a system will result in a detectable impact, you may wish to concentrate on capturing logs for behaviours that are indicative of impacts that are most important to you – such as attempts to wipe disks or corrupt firmware. Consider each element in the [Impact technique list](#) and address each that you care about. For example, you may prioritise defacement if you feel that reputational damage is unacceptable.

The fact you are logging these events will not stop the impact from occurring, but it will provide insight into how it occurred. In turn, this knowledge will help you prevent a recurrence, post remediation.

What about logs from the Cloud?



The cloud allows you to use resources as and when they are needed. However, depending on your provider, getting access to raw logs may be difficult or impossible. This is because of the division of ‘shared responsibility’. But what does shared responsibility mean for logging?

The cloud host is responsible for the logs *of* the cloud. That means that it may not be possible to get granular access to those logs, or change their verbosity, as the provider is responsible for this. If those logs are available, you may find them useful for informational or contextual purposes. [Section 13 of the NCSC’s Cloud Security Principles](#) describes how cloud providers should provide audit records.

Logs *in* the cloud are *your* responsibility. You need to consider opportunities to find those logging sources and expose them appropriately. This will be covered in depth in the upcoming transaction monitoring guidance, that is currently in development.

But what about _____?

We have used the ‘enterprise’ matrix as our example, but MITRE also provide matrices for Industrial Control System (ICS), Mobile (iOS/Android) and Network Infrastructure Devices.

You could use this same approach, though with a matrix of your choice, to review the effectiveness of your logging for mobile or network devices.

I have some logs. What next?

Aggregating logs to a central location as quickly as possible prevents the opportunity for an attacker to delete the logs that indicate their presence.

In some cases, you may wish to ensure a direct transmission of these events to a central repository using network controls, such as a one-way flow. This will help minimise the risk of an attacker compromising your log store. For some, aggregating logs to a central location is enough.

Logging Made Easy

The reason why the NCSC's Logging Made Easy project came into fruition is that it is far better to have something than nothing. A flight recorder, if you will. But the journey does not have to stop there. If you're willing to dig a bit deeper, or if you have a critical service that you are able to manage pro-actively, then you can consider tooling and analyst roles.

Right tools for the job

To be effective, analysts will need tools to help them interrogate and visual event data. There are a number of these tools available. Training may be required if you want your analysts to get the most from these tools.

Secure storage

Getting logs from their source to a central location securely is important too. You need to ensure that the logs arrive with assertions of integrity and confidentiality – for example, by cryptographically verifying logs, or moving them using Transport Layer Security (TLS). Depending on your network's sensitivity, you may wish to consider ways to logically separate the sources of logs from the analysis tool suite, to prevent tampering or deletion.

Storage duration

Once you have your logs, you may wish to consider the 'log-storage window'. This is the time you expect to be able to track initial access to detection. A short log-storage window would result in only seeing some of the attacker's actions. Yet, a log-storage time that is too long would mean that you are consuming much more processing and storage resources. In some critical areas, it is worth looking at a log-storage window time of 13 months. If your network is less critical, something like 180 days may be appropriate.

Log for Incident Management

Log collection and analysis can indicate what an attacker has done within your IT estate. Logs help to follow the methods they use, but on their own, will not prevent an attack from being successful. That is why the NCSC has published [Incident Management guidance](#) which provides guidance on effectively detecting, responding to and resolving cyber incidents.

Should you need to recover from an incident, your log collection will help you understand what the attacker has been up to and hopefully what vulnerabilities have been exploited, which will help direct remediation.

Conclusion

I have heard people say things like *“an attacker only needs to win once. Defenders need to win all the time.”* Maybe so, but the opposite also holds true – we have shown that a successful attack requires a multi-stage approach and an attacker needs to hide throughout their presence on a system and remain undetected which is a feat in itself.

Ensuring you have a breadth of logging sources is key to both mindsets. Increasing your coverage of common attack methods will help, but you should anticipate the need to evolve and adapt to emerging threats.

The MITRE ATT&CK framework is not the only framework that can be used in this way. You may find other frameworks such as Adversarial Misinformation and Influence Tactics and Techniques (AMITT) more relevant, or a combination of both.

Such frameworks serve to focus our attention on the type of events that can really help discover anomalous behaviour. They can apply to many uses and sectors, as discussed matrices exist for mobile, cloud and industrial control systems.

Your logging capability is like a torch shining in a darkened room. The more you craft the logging sources, the wider the beam illuminates – however, you should always review the limits of your logging capability and include feedback from past incidents.

For example, our [Logging Made Easy \(LME\)](#) project suggests using [SwiftOnSecurity's configuration](#), which provides a balance between usability and capturing the most interesting events. This configuration is always evolving and has some features that are seldom used. This highlights why identifying logging sources is a cyclic process.

Thanks for reading this blog-post, I know there's been a lot to take in, but hopefully you can now answer questions like "*what should I log?*" and "*for what purpose?*"

Adam B
Security Architect & LME Technical Lead

WRITTEN BY



Adam B
Senior Security Architect

PUBLISHED

18 March 2021

WRITTEN FOR

Cyber security professionals Large organisations Public sector

PART OF BLOG

NCSC publications